

MOSAIC: How to run and present the MVP

1. Start the project

This guide follows the current MVP. It covers setup, a suggested 8-10 minute demonstration, every main feature, and a complete new-evaluation example.

What to say first: "MOSAIC is a local risk-assessment gateway for the external resources an AI coding agent wants to use. It scores packages, skills, MCP servers and URLs, explains the evidence, and returns allow, review or deny."

Before the presentation

1. Install Node.js 22 or newer, which includes npm. Download or clone the MOSAIC repository from <https://github.com/FireFlamingo/MOSAIC>.
2. Open a terminal in the MOSAIC project folder. You should see package.json there. On this computer, the folder is:

```
C:\Users\amogh\OneDrive\Desktop\Assignments\EDI5\MOSAIC
```

3. Run these commands one at a time. The initial dependency installation needs internet access.

```
npm ci
```

```
npm run build
```

```
npm start
```

4. Keep that terminal open. Open <http://127.0.0.1:4318/> in your browser. Wait for "API reachable" in the header.
5. Open Policy. Set Hold for review to 50, Deny the request to 75, and Cross-artifact correlation to on. Click Save policy if you changed anything. These are the severity-v2 defaults used here. Existing saved evaluations retain earlier scores; submit or replay fresh requests.
6. Return to Overview. Rehearse once before presenting. Old observations remain saved; you do not need to clear them. Each replay creates a new session.

On presentation day

If dependencies are installed and the build is current, only run npm start, then open the same browser address. The built app and bundled fonts work locally without internet. Rebuild after changing the source. Stop the server afterwards with Ctrl+C in its terminal.

For development only, npm run dev serves the interface on port 4317 and the API on 4318. Use the single-server build above for a simpler presentation.

2. Suggested live presentation sequence

- 1. Introduce Overview (about 1 minute).** Show the total evaluations, allowed requests, pending reviews and denied requests. Explain that the supplied examples are synthetic inputs processed by the real local engine. The figures come from stored records, so totals depend on previous runs.
 - 2. Show a straightforward Allow (30 seconds).** Click Replay workflow, then Known publisher install. The new package scores 0 and is Allowed with the default policy. Explain: "No configured risk indicators matched the supplied evidence. This does not independently certify the package as safe."
 - 3. Demonstrate session correlation (about 2 minutes).** Replay Linked trust signals. The URL scores 100 and is Denied. The skill scores 75 and is Denied: unsigned provenance contributes 25; the linked name contributes 50. Generic history is shown with zero extra points because the stronger name signal already covers that group. Open Research & rationale to show a cited paper.
 - 4. Show filtering and navigation (30 seconds).** Close the details. Use the session dropdown to choose a session. Click View session to see only that session's requests. In Requests, try the artifact-type buttons, decision dropdown and search box. Clear filters before moving on.
 - 5. Create an evaluation live (about 2 minutes).** Click New evaluation and enter the example on page 3. Submit it, show the 50-point breakdown, expand Supplied metadata & content, and point out the session, scoring version, policy used and hash-linked receipt.
 - 6. Resolve a review (about 1 minute).** Enter Reviewer note: "Presentation example: reviewed the supplied metadata." Click Allow request. Show the recorded review. In Review queue, the resolved request is no longer pending. Its original score remains 50. Replay Young integration needs review for another held request to demonstrate Deny request.
 - 7. Demonstrate policy (about 1 minute).** In Policy, move the Decision preview slider: 0-49 Allow, 50-74 Needs review, 75-100 Deny. Turn correlation off and save; replay Linked trust signals. Its skill now scores 25 and is Allowed. Restore correlation afterwards. Previewing creates no records and existing evaluations do not change.
 - 8. Finish with the audit trail (30 seconds).** Click Export audit trail, or Download audit on Overview. Show the downloaded mosaic-audit.json file. Explain that records persist across restarts and that original evaluation receipts can be checked offline.
- Closing sentence:** "This MVP demonstrates one explainable scoring and review workflow across four artifact types. Automatic interception and independently verified evidence are work for the final project."

3. How to create a new evaluation

Use review 50, deny 75 and correlation on. Choose a fresh session ID, such as presentation-review-01. Use -02, -03 and so on for later rehearsals.

Enter this complete example

1. Click **New evaluation** in the upper-right area. On a narrow screen, it appears below the page heading. The keyboard shortcut is N when you are not typing in a field.
2. Select **MCP server** under Artifact type. This selects the kind of resource being assessed; it does not connect to a real server.
3. Set **Artifact name** to presentation-notes.
4. Set **Session ID** to presentation-review-01, or another fresh ID.
5. Set **Source** to https://example.invalid/tools. This is a synthetic example address and is not fetched.
6. Leave **Artifact existence** as Unknown.
7. Set **Signature** to Reported unsigned.
8. Set **Age in days** to 6.
9. Set **Downloads** to 18.
10. Expand **Content & permissions**. Enter "Summarise the selected project notes." as Static content. Check only network:egress; leave the other permissions unchecked.
11. Click **Evaluate request**. The evaluation details should open automatically.

What you should see

Expected result: 50/100, Needs review. Identity & provenance contributes max(existence unknown 25, reported unsigned 25) = 25. Network capability contributes 25. Total: 25 + 25 = 50. Unsigned is retained as supporting evidence with zero extra points. Age 6 and downloads 18 are context only. This assumes default policy and no earlier session activity.

The details show each reason and its points, request context, the original decision, supplied metadata/content and the receipt hash. Enter a Reviewer note, then choose Allow request or Deny request. Without a non-empty note, the review buttons stay disabled.

What the fields mean

Artifact name and Session ID are required. A session groups related requests; reuse an ID only when you want their history connected. Source is an optional location label. For Remote URL, fill URL to evaluate with a full URL; if omitted, the engine tries the artifact name as the URL.

Existence and signature values are reports supplied by you, not independently verified facts. Unknown means the information was not supplied. Age and downloads are optional non-negative whole numbers. Leave them blank when unknown: entering zero explicitly means an age of zero or zero downloads. Text and permissions are optional static evidence. Nothing submitted is installed, fetched or executed.

4. Feature checklist

Four artifact types. Package assesses a software library request. Skill assesses agent instructions or rules. MCP server assesses a proposed external tool server. Remote URL assesses a proposed URL. All use one request format and the same scoring/review workflow.

Risk scoring and explanations. Severity weights follow Zahan et al., IEEE Security & Privacy (2023). Take the strongest signal in each of five evidence groups, sum those points, and cap at 100. Rules cover identity/provenance, capabilities, static content, URL/transport and session context. Age and downloads add no points. Classifications and grouping are MOSAIC adaptations.

Overview and totals. See total, allowed, pending-review and denied counts. Click a total to open the corresponding request list. Overview includes the active policy summary, session trace, decision stream and review inbox.

Session trace. Choose a session from its dropdown, inspect individual events and open View session. The visual trace shows the latest five events; the request list contains the session's full recorded history. Related earlier requests can add points to later evaluations.

Search and filters. Requests supports artifact-type buttons, a decision dropdown, search by artifact name/source/session, a session filter, clear filters and pagination. Search is case-insensitive. N opens an evaluation, / focuses search, and Escape closes dialogs.

Evidence inspector. Open an artifact name, inspect arrow, trace node or review card. See score, verdict, included/supporting signals, paper links, model version, policy used, request context, supplied evidence and SHA-256 receipt hash. Older records are labelled Earlier scoring model.

Review inbox and queue. The inbox highlights held requests; Review queue lists pending decisions. A required note accompanies each human Allow or Deny. The resolved verdict is displayed without changing the original score or receipt. A resolved review cannot be reviewed again through this UI.

Policy editor. Type thresholds or use sliders; review must be lower than deny. Save policy, discard edits, toggle correlation, and try a score in Decision preview. Changes apply to future evaluations; previewing alone creates no evaluation.

Four replay workflows, using default policy. Known publisher install: 0, Allowed. Young integration needs review: 50, Needs review. Linked trust signals: URL 100, Denied, then skill 75, Denied; correlation off makes the skill 25, Allowed. Over-privileged unknown source: 100, Denied. Replays use the real API and fresh sessions.

Storage, export and integration. Evaluations, reviews and policy persist in data/state.json. Export the audit as JSON and verify the original evaluation chain offline. A local HTTP API supports evaluations, reviews, policy, replay, state retrieval, health and export; a cooperating caller must obey its decisions.

Usability. The layout adapts to desktop and mobile. Refresh loads the latest saved state. Failed submissions retain the form; Reconnect lets you retry. Replay supports keyboard arrows. Manrope headings and Public Sans interface text are bundled with the app.

5. Questions and quick fixes

What the MVP does and does not prove

Does Allow install or run the artifact? No. MOSAIC records a decision. It never executes the submitted artifact. An integrating agent or caller would have to use the decision before proceeding.

Does it already protect all agent activity automatically? No. Automatic command interception, agent adapters, MCP proxying and HTTP enforcement are not implemented in this MVP.

Does it verify the registry, website or signature? No. Metadata and text come from the caller. URL checks parse the address locally. Live registry lookups, reputation feeds and signature verification are future work.

Is 50 a 50% chance of an attack? No. It is a severity index using published weight ratios and our documented adaptations. A low score does not establish safety. Functional tests are not a labelled research benchmark; detection accuracy has not been measured.

What is special about correlation? Earlier non-allowed requests of other types can add 25 context points. A shared name strengthens that same group to 50; both are not added together. The latest 20 earlier session evaluations and their original policy decisions are considered. This uplift is a hypothesis awaiting evaluation.

Are receipts digitally signed? No. Original evaluations are SHA-256 hash-linked. Verification can detect changed content or broken links, but cannot authenticate the author or detect an entirely rewritten chain. Review and policy events are recorded separately and are not authenticated by that chain.

If something goes wrong during the demonstration

npm is not recognised: install Node.js 22 or newer and reopen the terminal. **package.json cannot be found:** move into the MOSAIC folder before running the commands.

The browser will not open the app / Gateway offline: check that npm start is still running, use `http://127.0.0.1:4318/`, then choose Reconnect or the header refresh button. If the terminal says the port is already in use, check whether an existing MOSAIC server is already running.

A result differs from this guide: restore review 50, deny 75 and correlation on. Use exact values and a new session. Old records keep their earlier scoring model; replay or submit a fresh evaluation.

The review queue is empty: replay Young integration needs review, or submit the example on page 3.

A request is missing: clear type, decision, search and session filters, then check the next page. **The look appears outdated:** rebuild the project and refresh the browser.

To verify an export: from the project folder run the following, replacing the quoted path with the actual downloaded file location:

```
npm run verify:audit -- "C:/path/to/mosaic-audit.json"
```

For an optional pre-presentation check, run `npm run check` and `npm run test:browser`. Browser tests use installed Edge on Windows; on other platforms, install the test browser with `npx playwright install chromium` first. These tests use separate temporary data, leaving your saved presentation records intact.

6. Explain the weights to the panel

Source of the numbers: Zahan et al., "OpenSSF Scorecard: On the Path Toward Ecosystem-Wide Automated Security Metrics," IEEE Security & Privacy, 21(6), 76-88, 2023. DOI: 10.1109/MSEC.2023.3279773. Section II explicitly reports Low 2.5, Medium 5, High 7.5 and Critical 10. Read the accessible author manuscript at <https://arxiv.org/html/2208.03412v3#S2>.

Why 25, 50 and 75? We multiply those published severity weights by ten to use a 0-100 display. The 1:2:3:4 ratios remain unchanged. They express priority, not attack probabilities. Critical 100 is reserved for a future independently confirmed-threat detector; current combined scores can reach the 100 cap.

Why these categories? Weak proxies such as uncertain provenance or encoding are Low. A trust-boundary concern or stronger linked identifier is Medium. Reported nonexistence, remote execution patterns or instruction overrides get conservative High priority. The papers support these concerns; MOSAIC assigns the categories. There has been no independent expert validation yet.

Why remove age/download penalties? We found no basis for universal "under 7 days" or "under 50 downloads" boundaries. Popular projects can be compromised and new projects can be legitimate. These fields remain context for the reviewer.

Why group the points? Unknown existence and unsigned status both concern provenance. Generic earlier activity and a shared name both concern session context. Taking the strongest within each group avoids counting the same family repeatedly. This is our transparent design choice, not Scorecard's original weighted-average algorithm.

Why review 50 and deny 75? These boundaries correspond to one Medium and one High concern. They are operational policy choices tied to the severity scale. They are not claimed to optimise false positives or detection.

Presentation wording: "We adopted a severity-weight scale documented in peer-reviewed IEEE research. Security conference papers motivate our signals. We adapted the scale for agent requests, grouped related evidence, and provide the full calculation. The MVP is a reproducible risk rubric; final accuracy and thresholds will be calibrated on labelled benign and malicious workflows."

Supporting conference papers: Spracklen et al., USENIX Security 2025, on hallucinated packages; Ohm et al., DIMVA 2020, on malicious supply-chain attacks; Sejfia and Schäfer, ACM/IEEE ICSE 2022, on malicious npm detection; Abdelnabi et al., ACM AISec 2023, on indirect prompt injection. Complete references and every signal's rationale are in MOSAIC-Scoring-Rationale.pdf and docs/SCORING.md.